

13-AI-SECURITY-RULES.md

Version : V1.0

Statut : ACTIVE

Catégorie : AI Engineering Framework

Projet : Vitala

1. Objectif

AI-SECURITY-RULES.md définit les règles obligatoires de sécurité applicables à toutes les modifications réalisées par une IA sur Vitala.

Toute IA doit considérer la sécurité comme une exigence obligatoire et non comme une amélioration optionnelle.

2. Principe fondamental

La règle principale est :

Aucune fonctionnalité ne doit être développée au détriment de la sécurité.

Une solution rapide mais dangereuse est considérée comme incorrecte.

3. Priorité de sécurité

Lorsqu'une décision implique un compromis :

L'ordre obligatoire est :

1. Protection des utilisateurs
2. Protection des données
3. Contrôle des accès
4. Intégrité du système
5. Performance

4. Gestion des données utilisateurs

Toute donnée utilisateur doit être considérée comme sensible.

L'IA doit :

- limiter la collecte ;
- protéger le stockage ;
- contrôler les accès ;
- éviter les copies inutiles.

L'IA ne doit jamais :

- exposer des données privées ;
 - afficher des informations non autorisées ;
 - transmettre des données sensibles inutilement.
-

5. Authentification

Toute fonctionnalité nécessitant une identité doit utiliser le système d'authentification officiel Vitala.

L'IA ne doit jamais créer :

- un système d'identification parallèle ;
 - une gestion de mot de passe indépendante ;
 - une session non contrôlée.
-

6. Autorisation et permissions

L'authentification répond à :

"Qui es-tu ?"

L'autorisation répond à :

"Que peux-tu faire ?"

Ces deux concepts doivent toujours être séparés.

L'IA doit vérifier les permissions avant toute action sensible.

7. PostgreSQL et RLS

La sécurité des données PostgreSQL doit utiliser :

- Row Level Security ;
- politiques explicites ;
- contrôle des rôles.

Interdit :

- désactiver RLS ;
 - contourner les politiques ;
 - donner un accès global inutile.
-

8. Règles Supabase

Toute IA travaillant avec Supabase doit respecter :

Auth

- sessions sécurisées ;
- utilisateurs contrôlés ;
- permissions cohérentes.

Database

- migrations contrôlées ;
- RLS activé ;
- schéma documenté.

Storage

- règles d'accès ;
- validation des fichiers ;
- limitation des tailles.

Edge Functions

- validation des entrées ;
 - authentification ;
 - gestion des erreurs.
-

9. Gestion des secrets

L'IA ne doit jamais :

- écrire une clé API dans le code ;
- exposer une variable privée ;
- publier un secret dans un repository.

Les secrets doivent utiliser :

- variables d'environnement ;
 - systèmes de secrets officiels.
-

10. Sécurité API

Toute API doit :

- authentifier les demandes ;
- vérifier les permissions ;
- valider les entrées ;
- limiter les abus ;
- retourner des erreurs contrôlées.

Interdit :

- endpoint public sans justification ;
 - données sensibles dans les réponses ;
 - absence de validation.
-

11. Validation des entrées

Toutes les données provenant de l'extérieur doivent être considérées comme non fiables.

Sources concernées :

- utilisateur ;
- API externe ;
- fichier ;
- formulaire ;
- IA.

L'IA doit prévoir :

- validation ;
- nettoyage ;
- limites.

12. Sécurité Frontend

Le frontend ne doit jamais être considéré comme sécurisé.

L'IA ne doit pas placer uniquement côté frontend :

- permissions ;
- règles critiques ;
- secrets ;
- logique de sécurité.

Toute protection importante doit exister côté serveur.

13. Sécurité des fichiers

Pour les fichiers utilisateurs :

L'IA doit gérer :

- type ;
- taille ;
- permissions ;
- stockage ;
- accès.

Interdit :

- accepter n'importe quel fichier ;
 - exposer un chemin privé ;
 - permettre un accès non contrôlé.
-

14. Sécurité des fonctionnalités IA

Toute fonctionnalité IA doit protéger :

- les données envoyées au modèle ;
- les réponses générées ;
- les permissions ;
- les coûts.

L'IA ne doit jamais :

- envoyer des données privées sans justification ;
- accepter une commande dangereuse générée automatiquement ;
- donner un accès administratif incontrôlé.

15. Administration Vitala

Les fonctionnalités administratives doivent avoir :

- permissions élevées contrôlées ;
- journalisation ;
- séparation des rôles ;
- traçabilité.

Une interface admin ne doit jamais être considérée comme une zone de confiance automatique.

16. Logs et surveillance

Les logs doivent aider à détecter :

- erreurs ;
- abus ;
- comportements suspects.

Les logs ne doivent jamais contenir :

- mots de passe ;
 - tokens ;
 - données privées inutiles.
-

17. Gestion des incidents

En cas de problème de sécurité :

L'IA doit :

1. identifier le risque ;
2. limiter l'impact ;
3. documenter ;
4. proposer une correction.

Elle ne doit jamais masquer un problème.

18. Vérification avant livraison

Avant validation :

[] Authentification vérifiée

[] Permissions vérifiées

[] RLS vérifié

[] Secrets protégés

[] Entrées validées

[] Erreurs contrôlées

[] Logs sécurisés

[] Données protégées

19. Interdictions absolues

Une IA ne doit jamais :

- ✗ désactiver une sécurité pour résoudre un bug.
 - ✗ exposer une donnée privée pour faciliter un test.
 - ✗ créer un accès administrateur caché.
 - ✗ stocker des secrets dans le code.
 - ✗ contourner RLS.
 - ✗ supprimer des contrôles de permission.
-

20. Règle finale

La sécurité est une propriété fondamentale de Vitala.

Une fonctionnalité non sécurisée est considérée comme une fonctionnalité incomplète.

Historique

Version	Modification
V1.0	Création des règles sécurité IA

Fin de AI/13-AI-SECURITY-RULES.md